

School: Denver Primary School

Date: 01/02/2022

Report: Remote consultation – Spring Term Agenda

DPE: Linda Mortimer

Staff member: Annette De Vanche, School Secretary

Consultation details

1. Review of actions from previous meeting (Autumn Term Agenda)
2. Review of GDPR status, compliance documents
3. Information security and e-learning training
4. Supplier due diligence
5. Data retention
6. Raising staff awareness and audit walks
7. DPE events and webinars
8. Record of processing (RoP) update

1. Review of actions identified at time of Autumn Term Agenda

The school uploaded their current versions of the Data Protection Policy and Privacy Notice in September 2020. Are there any plans to review these and will they also consider publishing a child friendly version the the Privacy Notice (available on Knowledge Bank).

Training – are the GDPR refresher courses timelined for staff. The ICO recommends that general GDPR refresher courses should be completed every 2 years.

As discussed, to help mitigate the risk of cyber attacks, have staff been assigned training to help raise their awareness. This would include DPE's Staying Safe Online as a priority also backed up by Password Security.

The school raised a query relating to which Data Protection policies the school must have in place and also whether any others should be added to the school's website. Please see Item 2 below for further details.

2. Review of GDPR status, compliance documents, website and internal documentation

By now you should have all of your main updated compliance documents. Although the documents below are not all statutory to have on your website, for transparency and ease of managing these documents, it is good practice to have a GDPR section on your website and consider including the following documents:

Website documents:

- GDPR policy
- Privacy notice(s)
- SAR and data breach procedure
- FOI Policy
- Supplier/third party list

Other useful documents to review and check that you have are:

- Work away from school policy
- Review of consent documentation. Consent guidance and consent withdrawal can also be added to the GDPR section of the school website

For data retention (section 5 below) there is a records management best practice area and documentation for records management and Information classification. If your data protection policy refers to these documents then you should also have these documents in place: <https://dataprotection.education/best-practice-library/best-practice/records-management>

3. Supplier due diligence

The controller is responsible for assessing that any third party processors (suppliers etc) are competent to process personal data in line with the UK GDPR's requirements. This assessment should take into account the nature of the processing and the risks to the data subjects. This is because Article 28(1) says a controller must only use a processor that can provide "sufficient guarantees" (in particular in terms of its expert knowledge, resources and reliability) to implement appropriate technical and organisational measures to ensure the processing complies with the UK GDPR and protects the rights of individuals.

Things to consider:

- Privacy notice/third party/supplier list - is this up to date, do you know all the organisations/suppliers you share information with?
- Due diligence form - this can be sent to new suppliers
- Make sure that current and future contracts include data protection
- Risks - what you should be thinking of when purchasing and using new products and suppliers
- If using GDPRiS for maintaining suppliers, make sure that this is updated and accurate

DPEs best practice area and the due diligence form for suppliers is located here:

<https://dataprotection.education/index.php/best-practice-library/best-practice/due-diligence-best-practice-area>

4. Information security (phishing simulation) and e-learning training

DPE have a number of resources for information security: <https://dataprotection.education/best-practice-library/documents/information-technology-security>

If not already, staff should complete the **Stay Safe online NCSC training**. This is not only beneficial for the organisation but also for staff when accessing personal information online i.e. personal banking: <https://dataprotection.education/courses-heading/stay-safe-online-ncsc>

There is also an information classification best practice area: <https://dataprotection.education/index.php/best-practice-library/best-practice/information-classification>

And DPE will be releasing a phishing simulation shortly.

In addition, you can check out the National Cyber Security Centre website: [ncsc.gov.uk](https://www.ncsc.gov.uk) which has useful resources and tips for schools regarding cyber security:

- **School resources:** <https://www.ncsc.gov.uk/section/education-skills/schools>
- **Governor Qs for schools:** <https://www.ncsc.gov.uk/information/school-governor-questions>

Check out the DPE news articles on the Education sector now being at the highest risk of cyber attacks-
<https://dataprotection.education/news/166-information-security/203-the-education-sector-now-at-highest-risk-of-cyber-attacks>

<https://dataprotection.education/news/166-information-security/220-assessing-the-state-of-your-data-security>

5. Data retention

Organisations can set deadlines, document and justify timeframes they have set for retaining data. There are **two key factors**: the **purpose** for processing the data, and any **legal or regulatory requirements** for **retaining it**. One of your purposes will need to apply for you to continue to store the data. Data should not be held for longer than is needed. You shouldn't just keep data just in case you may need it in the future.

Different data systems to consider when reviewing data retention:

- Emails
- MIS
- Website
- Network/CLOUD

Tools to support you:

- There are a number of tools to support you with data retention: [IRMS](#) tool kit
- DPE's [record management](#) best practice area and records management policy
- [DfE](#) Annual review of school records and safe data destruction checklist
- [ICO](#)
- DPEs [Record of Processing \(RoP\)](#)
- Your third party list within your privacy notice
- Laws and regulations (for example, financial regulations and handbooks and limitations act:
<https://www.legislation.gov.uk/ukpga/1980/58/legislation>:
<https://www.legislation.gov.uk/ukxi/2021/833/contents/made>)
- [Microsoft retention tools](#)
- [Google retention tools](#)
- [MIS retention tools](#)
- Network scanning and retention tools - speak to your IT department

6. Raising staff awareness and audit walks

As demonstrated at the time of the last meeting in the Autumn Term, there is now a **Making the rounds electronic audit walk** that can be completed by you in school. This tool will also be used by consultants when we visit. By completing electronically, allows you to log and keep a record and is accessible via the My Activities tab on the DPE website: <https://dataprotection.education/courses-heading/making-the-rounds-log>

Why not use staff briefings and having a monthly focus i.e. clear desks and locking laptops etc. This is an ideal way to raise awareness and keep staff focused with the latest data protection issues.

7. DPE events and workshops

Check out the latest webinars and workshops from the My Activities section of the DPE website. The next workshop is a **data retention workshop** on the 10th February: <https://dataprotection.education/courses-heading/dpe-events>

8. Record of Processing (RoP) - and DPE methodology

The following RoPs were completed at the time of the meeting:

HR05	Managing the SCR
FIN24AM	Managing BACS payments

This means that the initial RoPs copied into the school's RoP manager on Knowledge Bank have now been tailored and completed to reflect the actual practice at the school.

There are many other standard RoPs which can be found in the Generic School and these can be easily copied in the schools specific RoP area for completion.